

TOSCANA DIAGNOSTICA S.r.l.

Sistema di Gestione Integrato

DISASTER RECOVERY PLAN

Area 08 – Sistema Informativo

Codice	Revisione	Data	Pagine
TD-SGI-PLN014_00	00	30/04/2026	4
Redatto da	Approvato da	Classificazione	Stato
IT Manager + RSGI	AD – Francesco Epifani	Riservato Alta Direzione + IT + Auditor	In vigore

Responsabile del Documento	RSGI	Emissione del Documento
Francesco Epifani	Iacopo Cupelli	Francesco Epifani
29/04/2026	29/04/2026	29/04/2026

Toscana Diagnostica S.r.l.

Via di Pratignone, 13/4, 50019 Sesto Fiorentino (FI). Tel. e Fax: 055776511. Direttore Sanitario: prof. Gian Luigi Taddei.
P.IVA e C.F.: 07528130482, REA n. FI-709602 – Capitale Sociale: € 50.000,00 i.v.

1. Scopo e ambito

Il Disaster Recovery Plan (DRP) di Toscana Diagnostica S.r.l. costituisce la componente ICT del Business Continuity Plan TD-SGI-PLN013 e definisce le procedure tecniche per il ripristino dei sistemi informativi a fronte di un evento disruptive maggiore.

Il DRP è coerente con: ISO/IEC 22301:2019; ISO/IEC 27001:2022 §A.5.29-A.5.30, A.8.13-A.8.14; D.Lgs. 138/2024 (NIS2) area MTOM 3.

Ambito: tutti i sistemi e le infrastrutture ICT critiche di TD - LIS, RIS/PACS, AD, file server, mail M365, portale paziente, ERP, conservazione sostitutiva, middleware IVD, infrastruttura di rete.

2. Riferimenti

Riferimento	Ambito
TD-SGI-PLN013	Business Continuity Plan (BCP - documento padre)
TD-SGI-PRO109	Information Security Policy operativa
TD-SGI-PRO070	Procedura NIS2 - cyber-incident
TD-SGI-MOD181	Registro Incidenti significativi
TD-SGI-MOD221	Verbale test BCP/DRP
ISO/IEC 22301 + ISO 27001 §A.5.30	Framework metodologico

3. Architettura di Disaster Recovery

L'architettura di DR di TD si basa su tre livelli di resilienza:

(a) Resilienza locale (alta disponibilità): server LIS in cluster attivo-attivo; storage ridondato; UPS + generatore; rete con doppio uplink.

(b) Resilienza geografica (sito remoto): backup off-site cifrato giornaliero su provider cloud diverso dal primario; replica asincrona per i dati clinici verso storage geograficamente distinto; RPO ≤ 4h per LIS, ≤ 12h per altri sistemi.

(c) Resilienza di sistema (rebuild da zero): documentazione architetturale + golden image dei server + esecuzione end-to-end dei runbook documentati per ricostruire qualsiasi servizio in ≤ 24h su nuova infrastruttura.

4. Obiettivi RTO / RPO per servizio

Servizio ICT	RTO target	RPO target	Modalità di ripristino	Owner
LIS (Laboratory Information System)	≤ 4 ore	≤ 1 ora	Failover su nodo passivo + restore da backup geografico	IT Manager + Vendor LIS
RIS / PACS (Imaging)	≤ 4 ore	≤ 2 ore	Failover + restore + ricostruzione archivio immagini	IT Manager + Vendor RIS/PACS
Active Directory + Identity	≤ 2 ore	≤ 15 minuti	Failover su DC secondario	IT Manager
Mail / M365	≤ 8 ore	≤ 1 ora	Cloud nativo (Microsoft) - SLA fornitore + restore mailbox da backup	IT Manager

Portale paziente / refertazione esterna	≤ 8 ore	≤ 4 ore	Restore da backup cloud	IT Manager
ERP / Fatturazione SSN	≤ 24 ore	≤ 24 ore	Restore da backup; in transitorio gestione manuale	CFO + IT Manager
Conservazione sostitutiva	≤ 24 ore	≤ 24 ore	Servizio gestito dal fornitore - SLA contrattuale	DPO + IT Manager
Middleware IVD (strumentazione lab)	≤ 4 ore	≤ 4 ore	Restore + reinstallazione driver - in transitorio modalità diretta strumentazione	IT Manager + Direttore Lab
Infrastruttura di rete (firewall, switch core)	≤ 4 ore	—	HW di scorta + restore configurazione	IT Manager

5. Backup strategy

Sistema	Frequenza	Retention	Localizzazione	Cifratura
LIS - DB clinico	Giornaliero (incrementale 4h)	90 giorni + 1 anno cold storage + 10 anni archivio referti	Datacenter primario + cloud off-site (provider distinto)	AES-256 at-rest + in-transit
RIS/PACS imaging	Giornaliero (full notturno)	90 giorni + 5 anni cold storage	Datacenter primario + cloud off-site	AES-256
Active Directory	Giornaliero (system state)	30 giorni + snapshot 2/sett 1 anno	Sito locale + cloud	AES-256
File server	Giornaliero (delta)	60 giorni + snapshot mensile 1 anno	Sito locale + cloud	AES-256
Mail / M365	Continuous snapshots 4/giorno	90 giorni + Litigation Hold per ruoli critici	Cloud nativo (Microsoft)	Microsoft - AES-256
Configurazioni infrastruttura (firewall, switch, AP)	On change + settimanale	12 mesi	Sito locale + cloud	AES-256

Tutti i backup sono testati per restore con cadenza almeno annuale. La regola 3-2-1 è applicata: 3 copie totali, 2 supporti diversi, 1 copia off-site.

6. Procedura operativa di Disaster Recovery

Step	Azione	Owner	T target
1	Allerta dell'evento (SOC, monitoraggio, segnalazione utente)	Chi rileva	T0
2	Apertura ticket prioritario, attivazione reperibilità IT, allerta CMT (BCP)	IT Manager	T0+15'
3	Valutazione impatto: quali servizi giù? RTO/RPO target?	IT Manager + RSGI	T0+30'
4	Decisione: failover locale (HA) o failover geografico (DR sito remoto) o rebuild?	IT Manager + AD	T0+45'
5	Attivazione modalità BCP (PLN013 §6) per le	RSGI + Direttore	T0+1h

	attività degli utenti	Lab + Direttore Sanitario	
6a (HA)	Failover su nodo passivo del cluster + verifica integrità dati	IT Manager + Vendor	Entro RTO
6b (DR)	Restore da backup geografico (in ordine di priorità: LIS, AD, mail) + ripristino connettività rete	IT Manager + Vendor	Entro RTO
6c (Rebuild)	Esecuzione runbook di rebuild da documentazione architetturale	IT Manager + Vendor	Entro 24h
7	Verifica funzionale post-ripristino: test integrità dati, conformità configurazione, prove utente	IT Manager + Direttore Lab	Entro RTO+1h
8	Comunicazione di ripristino al CMT e agli utenti finali	RSIG	Entro RTO+2h
9	Post-incident: forensic readiness, lesson learned, root cause analysis, CAPA	RSIG + IT Manager	T0+30gg
10	Aggiornamento del DRP in base ai risultati	RSIG	T0+60gg

7. Test del DRP

Il DRP è testato secondo il calendario definito nel BCP §8: walk-through semestrale, tabletop annuale, test funzionale annuale, test full-scale triennale. Ogni test è verbalizzato in TD-SGI-MOD221 con: scenario eseguito, partecipanti, sequenza azioni, RTO/RPO effettivamente misurati, esito (Successo / Successo parziale / Fallimento), CAPA, lessons learned.

8. KPI di Disaster Recovery

KPI	Target	Frequenza
Rispetto RTO in test annuale	100%	Annuale (test funzionale)
Rispetto RPO in test annuale	100%	Annuale
% backup testati per restore	100%	Annuale
Tempo medio rilevazione DR-trigger event	≤ 30 minuti	Trimestrale
Tempo medio attivazione DRP da rilevazione	≤ 30 minuti	Trimestrale
Numero falsi positivi DR-trigger	Tracciato	Trimestrale

9. Storico delle revisioni

Rev.	Data	Descrizione	Redatto	Approvato
00	30/04/2026	Prima emissione del documento	IT Manager + RSIG	AD